

Cisco SD-WAN & Firewall Management Center

Critical Vulnerability Campaign — CVE-2026-20182, 20133, 20079, 20131, 20127

Threat Intelligence Report | Published: 15 May 2026 | Lost Boys Cyber

URGENT — CISA Emergency Directive 26-03 Active

Mandate: CISA Emergency Directive 26-03 orders all US federal agencies to patch all in-scope Cisco Catalyst SD-WAN systems. The deadline for remediation under the updated directive is 17 May 2026. Non-federal organisations should treat this timeline as a critical benchmark.

KEV Status: All five CVEs in this campaign are now listed in CISA's Known Exploited Vulnerabilities catalog. CVE-2026-20182 was added on 14 May 2026 — the date of this advisory update.

Active Exploitation: Cisco PSIRT and Talos have confirmed active exploitation by UAT-8616 and at least 10 additional threat clusters following the release of public proof-of-concept code.

CVE-2026-20182 — SD-WAN Controller Auth Bypass

Attribute	Detail
CVE ID	CVE-2026-20182
CVSSv3.1 Score	10.0 — Critical CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Vulnerability Type	Authentication Bypass — CWE-287: Improper Authentication
Affected Component	Cisco Catalyst SD-WAN Controller — vdaemon service (DTLS, UDP port 12346)
Affected Versions	SD-WAN releases 20.9 through 26.1 (all prior to fixed releases)
Disclosure Date	14 May 2026 (CISA KEV addition) Advisory updated 14 May 2026
Attack Vector	Network — Unauthenticated, Remote
Exploit Status	Actively exploited in the wild — UAT-8616 confirmed. PoC publicly available.
Patch Available	Yes — upgrade to fixed SD-WAN release (see Section 4)
KEV Listed	Yes — added 14 May 2026

CVE-2026-20133 — SD-WAN Manager Information Disclosure

Attribute	Detail
CVE ID	CVE-2026-20133
CVSSv3.1 Score	7.5 — High CVSS Vector: AV:N/AC:L/Au:S/C:C/I:N/A:N
Vulnerability Type	Information Disclosure — CWE-200: Exposure of Sensitive Information
Affected Component	Cisco Catalyst SD-WAN Manager — REST API (insufficient file system access restrictions)
Affected Versions	SD-WAN Manager — multiple releases prior to fixed versions
Disclosure Date	25 February 2026 KEV added 14 May 2026
Attack Vector	Network — Authenticated (low-privilege API access)
Exploit Status	Actively exploited — chained with CVE-2026-20128 and CVE-2026-20122 for unauthenticated access
Patch Available	Yes — patches released February 2026
KEV Listed	Yes — added 14 May 2026

CVE-2026-20079 — Secure FMC Authentication Bypass

Attribute	Detail
CVE ID	CVE-2026-20079
CVSSv3.1 Score	10.0 — Critical Maximum severity
Vulnerability Type	Authentication Bypass — improper system process created at boot time
Affected Component	Cisco Secure Firewall Management Center (FMC) — web management interface
Affected Versions	FMC prior to 7.0.9 / 7.2.11 / 7.4.4 / 7.6.4 / 7.7.12 / 10.0.1
Disclosure Date	4 March 2026 Active exploitation confirmed March 2026
Attack Vector	Network — Unauthenticated, crafted HTTP requests to management interface
Impact	Execute scripts as root — full system compromise
Patch Available	Yes — upgrade FMC to a fixed release (no workaround exists)
KEV Listed	Yes — CISA KEV catalog

CVE-2026-20131 — Secure FMC Insecure Deserialization (RCE)

Attribute	Detail
CVE ID	CVE-2026-20131
CVSSv3.1 Score	10.0 — Critical Maximum severity
Vulnerability Type	Insecure Deserialization — arbitrary Java code execution as root
Affected Component	Cisco Secure FMC — web-based management interface (Java byte stream deserialisation)
Affected Versions	FMC prior to 7.0.9 / 7.2.11 / 7.4.6 / 7.6.5 / 7.7.12 / 10.0.1
Disclosure Date	4 March 2026 Active exploitation confirmed March 2026
Attack Vector	Network — Unauthenticated remote attacker sends crafted Java byte stream
Impact	Root-level RCE — attacker gains full control of FMC and managed firewalls
Patch Available	Yes — upgrade FMC (no workaround — flaw is in core management logic)
KEV Listed	Yes — CISA KEV catalog

CVE-2026-20127 — SD-WAN Controller Auth Bypass (Original Zero-Day)

Attribute	Detail
CVE ID	CVE-2026-20127
CVSSv3.1 Score	10.0 — Critical
Vulnerability Type	Authentication Bypass — vdaemon / DTLS peering (same service as CVE-2026-20182)
Affected Component	Cisco Catalyst SD-WAN Controller
Disclosure Date	25 February 2026 Exploited as zero-day since at least 2023 by UAT-8616
Attack Vector	Network — Unauthenticated, remote
Exploit Status	Actively exploited — initial access vector for UAT-8616 for 3+ years
Patch Available	Yes — included in February 2026 SD-WAN advisory
KEV Listed	Yes — CISA KEV catalog

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This report was generated with AI assistance from publicly available sources. All findings, detection rules, and recommendations must be independently reviewed by a qualified security professional before being acted upon or implemented in any environment.

Query Disclaimer: All detection queries (Sigma, KQL, PowerShell) are generic templates requiring adaptation to your organisation's specific environment, data sources, field names, log formats, and SIEM/EDR platform configuration.

Currency: Information is based on publicly available sources as of 15 May 2026. The threat landscape for this campaign is evolving rapidly — verify all details against Cisco's official security advisories and CISA guidance before relying on this document.

1. Executive Summary

Cisco disclosed and updated a series of critical vulnerabilities on 14 May 2026 affecting two major enterprise product families: the Cisco Catalyst SD-WAN platform (Controller and Manager) and the Cisco Secure Firewall Management Center (FMC). The vulnerabilities span authentication bypass, information disclosure, and remote code execution primitives, with CVSS scores reaching the maximum 10.0. All five CVEs are now listed in CISA's Known Exploited Vulnerabilities catalog, and CISA has issued Emergency Directive 26-03 mandating federal agency remediation by 17 May 2026.

The SD-WAN vulnerabilities (CVE-2026-20182, CVE-2026-20133, CVE-2026-20127) have been actively exploited by a sophisticated threat actor designated UAT-8616, which Cisco Talos has tracked since at least 2023. CVE-2026-20127, the original zero-day in the vdaemon service, gave UAT-8616 unauthenticated administrative access to SD-WAN Controllers for over three years before disclosure. CVE-2026-20182 — a closely related vulnerability in the same service — was disclosed on 14 May 2026 and is already being exploited. Following the release of public proof-of-concept code, at least 10 additional, unrelated threat clusters have launched exploitation campaigns against exposed SD-WAN infrastructure.

The Secure FMC vulnerabilities (CVE-2026-20079 and CVE-2026-20131) allow an unauthenticated remote attacker to execute arbitrary code as root on the firewall management plane. Because Cisco FMC centrally manages Secure Firewall appliances (formerly Firepower), a compromise of FMC grants an attacker the ability to modify firewall policy, disable inspection, extract network topology data, and potentially pivot to managed firewall devices across the enterprise.

Organisations running any affected Cisco SD-WAN or FMC product should treat this as a critical incident requiring immediate patch deployment. Where immediate patching is not possible, implement the network segmentation and access restriction controls detailed in Section 4. Both platforms should be assessed for signs of prior compromise using the indicators and hunt queries in Sections 5 and 6.

2. Vulnerability Details

2.1 CVE-2026-20182 — SD-WAN Controller vHub Authentication Bypass

CVE-2026-20182 resides in the vdaemon service of the Cisco Catalyst SD-WAN Controller, which listens on UDP port 12346 using DTLS. This port carries Overlay Management Protocol (OMP) messages including route advertisements, Transport Location (TLOC) tables, and peer state information — the core of the SD-WAN overlay routing fabric.

The root cause is a missing certificate validation branch triggered when a peering device claims to be a vHub node. The vulnerable code section assists with peer certificate validation for SD-WAN implementations, but when the remote device identifies itself as a vHub during the DTLS handshake, the function contains no certificate verification logic — it simply trusts the peer identity and logs the attacker-controlled device as a legitimate SD-WAN peer with administrative privileges.

Post-authentication, an attacker can access the NETCONF interface and issue configuration changes to the entire SD-WAN fabric — including routing policy manipulation, TLOC injection, and credential

extraction from the Controller's configuration store. The vdaemon service is exposed on the WAN-facing interface by design, making network-level controls alone insufficient for most deployments.

2.2 CVE-2026-20133 — SD-WAN Manager API Information Disclosure

CVE-2026-20133 is an information disclosure vulnerability in the Cisco Catalyst SD-WAN Manager's REST API. The API fails to properly restrict file system access, allowing an authenticated user (even one with minimal privileges) to read sensitive files from the underlying operating system — including configuration data, credentials, and private keys. This vulnerability becomes critical when chained: CVE-2026-20128 and CVE-2026-20122 can provide unauthenticated access to the Manager, after which CVE-2026-20133 extracts high-value secrets, enabling full fabric compromise without requiring CVE-2026-20182.

2.3 CVE-2026-20079 — Secure FMC Authentication Bypass (Boot Process)

CVE-2026-20079 exploits an improper system process that is created during the Cisco Secure FMC boot sequence. This process exposes an unauthenticated code path in the FMC web management interface. An attacker who sends specifically crafted HTTP requests to the management interface can bypass the authentication layer entirely and execute scripts with root privileges. No credentials, session tokens, or prior access are required. Because the vulnerability is in the FMC's boot-time initialisation logic, there is no workaround — only a version upgrade resolves the issue.

2.4 CVE-2026-20131 — Secure FMC Insecure Java Deserialization

CVE-2026-20131 is an insecure deserialization vulnerability in the FMC's web-based management interface. The FMC accepts a Java byte stream from external clients without adequate validation. A crafted malicious byte stream, submitted by an unauthenticated remote attacker, triggers arbitrary Java code execution in the context of the FMC web process, which runs with root privileges. The result is full, unauthenticated root-level RCE on the management plane.

The compound impact of CVE-2026-20079 and CVE-2026-20131 on the FMC is severe: because the FMC centrally controls Cisco Secure Firewall (Firepower) appliances across the enterprise, an attacker with root access to FMC can silently modify firewall policy on every managed device, disable network inspection, exfiltrate network topology and access control policies, and pivot to managed firewall appliances using trusted management-plane communications.

2.5 CVE-2026-20127 — SD-WAN Original Zero-Day (UAT-8616 Initial Access)

CVE-2026-20127 is the original SD-WAN Controller authentication bypass exploited as a zero-day by UAT-8616 since at least 2023 — more than two years before public disclosure in February 2026. Like CVE-2026-20182, it targets the vdaemon service over DTLS on UDP/12346, abusing the peer authentication mechanism to gain administrative access without credentials. After gaining access via CVE-2026-20127, UAT-8616 was observed downgrading device software versions to re-expose CVE-2022-20775, enabling root-level privilege escalation.

3. Threat Landscape & Threat Actor Profile

3.1 UAT-8616 — Primary Threat Actor

UAT-8616 is a sophisticated, likely state-nexus threat actor that has been conducting intrusions against Cisco SD-WAN infrastructure since at least 2023. Talos attributes the exploitation of CVE-2026-20127 as a zero-day to UAT-8616 with high confidence, and the same actor's tooling has been identified in ongoing exploitation of CVE-2026-20182. The actor demonstrates advanced capability in abusing network infrastructure platforms — a pattern consistent with intelligence collection and persistent access campaigns rather than ransomware or destructive operations.

Post-exploitation TTPs observed from UAT-8616 include:

- SSH key injection into `authorized_keys` files on compromised controllers to establish persistent access
- Enabling `PermitRootLogin` in SSH daemon configuration to maintain root-level remote access
- Clearing forensic evidence: `syslog`, `wtmp`, `lastlog`, `bash_history`, and `cli-history` are wiped
- Software version downgrades via SD-WAN management APIs to re-expose legacy CVEs (e.g. CVE-2022-20775)
- NETCONF manipulation to alter SD-WAN fabric routing and insert rogue TLOCs
- Lateral movement from compromised controllers to SD-WAN Manager and connected edge devices

3.2 Expanded Threat Actor Landscape Post-PoC

Following the release of public proof-of-concept exploit code for the SD-WAN vulnerabilities, at least 10 additional, unrelated threat clusters have begun exploitation activity — a pattern consistent with opportunistic criminal actors leveraging ready-made tools. The scope and nature of these secondary actors is not yet fully characterised; organisations should assume broad, indiscriminate scanning of internet-exposed SD-WAN infrastructure is underway.

3.3 Strategic Impact of FMC Compromise

The FMC vulnerabilities present a uniquely high-value target because the FMC is the management plane for an organisation's entire Cisco firewall estate. A single FMC compromise can yield: complete visibility into the network security architecture; the ability to silently weaken or disable firewall rules across all managed devices; extraction of encrypted credentials stored in FMC for device management; and pivot paths to Secure Firewall appliances. Organisations that have positioned FMC as the source of truth for network security policy should treat any potential FMC compromise as a full network breach.

4. Mitigation & Patch Guidance

Patching is the only definitive remediation for all five CVEs. Access restriction controls listed below reduce exposure but should not be treated as substitutes for applying vendor fixes.

4.1 Cisco Catalyst SD-WAN — Fixed Releases

Upgrade Cisco Catalyst SD-WAN Controller and Manager to a fixed release. Cisco has released patches across all supported SD-WAN release trains. The following fixed versions address CVE-2026-20182 and CVE-2026-20127:

- 20.9.x → upgrade to 20.9.8 or later
- 20.10.x → upgrade to 20.10.2 or later
- 20.11.x → upgrade to 20.11.4 or later
- 20.12.x → upgrade to 20.12.4 or later
- 20.13.x → upgrade to 20.13.4 or later
- 20.14.x → upgrade to 20.14.3 or later
- 20.15.x → upgrade to 20.15.3 or later
- 20.16.x → upgrade to 20.16.2 or later
- 20.18.x → upgrade to 20.18.2 or later
- 26.1.x → upgrade to 26.1.2 or later

Always refer to the official Cisco Security Advisory (cisco-sa-sdwan-rpa2-v69WY2SW) for the definitive fixed-release list and any release-specific caveats before deploying.

4.2 Cisco Secure Firewall Management Center — Fixed Releases

Upgrade FMC to a fixed release. There are no workarounds for CVE-2026-20079 or CVE-2026-20131 — patching is mandatory. Note that different fixed versions apply to each CVE:

- 7.0.x → 7.0.9 (fixes both CVEs)
- 7.2.x → 7.2.11 (fixes both CVEs)
- 7.4.x → 7.4.4 (CVE-2026-20079) / 7.4.6 (CVE-2026-20131)
- 7.6.x → 7.6.4 (CVE-2026-20079) / 7.6.5 (CVE-2026-20131)
- 7.7.x → 7.7.12 (fixes both CVEs)
- 10.0.x → 10.0.1 (fixes both CVEs)

4.3 Network-Level Access Controls (Interim)

Where immediate patching is not possible, implement strict network-level controls as an interim measure. These controls reduce but do not eliminate risk:

- Restrict access to SD-WAN Controller vdaemon (UDP/12346) to known, trusted peer IP addresses only using infrastructure ACLs or firewall rules. Block all other sources.
- Restrict access to the Cisco Secure FMC web management interface (TCP/443) to management network CIDRs only — ideally a dedicated out-of-band management VLAN not reachable from general corporate networks.
- Ensure SD-WAN Manager is not directly reachable from the internet. Place it behind a VPN or zero-trust access gateway requiring strong authentication.
- Disable the FMC management interface from any interface that is internet-facing or reachable from untrusted networks.

- Review and revoke any unnecessary API tokens or service accounts configured on SD-WAN Manager.

4.4 Verify Integrity Post-Patch

Given UAT-8616's documented use of persistence mechanisms (SSH key injection, PermitRootLogin), patching alone is insufficient on systems that may have been exposed. After patching, verify:

```
# Check for injected SSH keys on SD-WAN Controller / Manager
cat /home/admin/.ssh/authorized_keys
cat /root/.ssh/authorized_keys

# Verify SSH daemon hardening has not been changed
grep PermitRootLogin /etc/ssh/sshd_config
grep AuthorizedKeysFile /etc/ssh/sshd_config

# Check current SD-WAN software version has not been downgraded
show version
show software # On vManage
```

5. Detection

5.1 SD-WAN — Key Indicators of Compromise

The following indicators are associated with UAT-8616 exploitation and post-exploitation activity on Cisco Catalyst SD-WAN infrastructure:

- Unexpected entries in /home/admin/.ssh/authorized_keys or /root/.ssh/authorized_keys
- PermitRootLogin set to 'yes' in /etc/ssh/sshd_config (should be 'no' in default Cisco builds)
- Gaps or truncation in syslog, wtmp, lastlog — indicating active log clearing
- Software version on SD-WAN Controller lower than expected / recently downgraded
- Unexpected NETCONF sessions originating from non-management IP addresses
- New or modified TLOC entries pointing to unrecognised IP addresses in the OMP routing table
- Unexpected SD-WAN peering connections from unknown IP addresses on UDP/12346

5.2 FMC — Key Indicators of Compromise

- Unexpected root-owned processes spawned from the FMC web application process (httpd or similar)
- Outbound connections from the FMC management interface to external IP addresses
- New user accounts or modified administrator accounts in FMC's user management interface
- Unexpected changes to firewall policy objects or access control rules across managed devices
- Anomalous API calls in FMC audit logs — particularly GET requests to sensitive API endpoints

- Web server access logs containing requests with anomalous Java-serialized byte stream Content-Type headers

5.3 Sigma Rule — Unexpected SD-WAN DTLS Peer (UDP/12346)

```
title: Cisco SD-WAN Unexpected DTLS Peer Connection
id: c7f34a91-ee82-4b3d-a501-7e2d11c9a041
status: experimental
description: Detects new DTLS peering connections to SD-WAN Controller on UDP/12346
             from IP addresses not in the known-good peer list.
             Indicative of CVE-2026-20182 / CVE-2026-20127 exploitation attempts.
author: Lost Boys Cyber
date: 2026-05-15
logsource:
  category: network_connection
  product: cisco
detection:
  selection:
    dst_port: 12346
    proto: udp
  filter_known_peers:
    src_ip|cidr:
      - '10.0.0.0/8'      # Adjust to your SD-WAN peer IP ranges
      - '172.16.0.0/12'
    condition: selection and not filter_known_peers
falsepositives:
  - Newly onboarded legitimate SD-WAN peers – validate against change records
level: high
tags:
  - attack.initial_access
  - attack.t1190
```

5.4 Sigma Rule — FMC Anomalous Web Process Child Execution

```
title: Cisco FMC Web Process Spawns Unexpected Child
id: d4a87b12-3c91-4f8e-b902-9e5a22f63d17
status: experimental
description: Detects shell or interpreter processes spawned by the FMC web server
             process, indicative of CVE-2026-20079 or CVE-2026-20131 exploitation.
author: Lost Boys Cyber
date: 2026-05-15
logsource:
  category: process_creation
  product: linux
detection:
  selection:
```



```

    ParentImage|endswith:
      - '/httpd'
      - '/java'
      - '/tomcat'
    Image|endswith:
      - '/sh'
      - '/bash'
      - '/python'
      - '/python3'
      - '/perl'
      - '/curl'
      - '/wget'
    condition: selection
falsepositives:
  - Legitimate Cisco FMC maintenance scripts – validate against baseline
level: critical
tags:
  - attack.initial_access
  - attack.execution
  - attack.t1190

```

5.5 Microsoft Sentinel / MDE KQL — SD-WAN Indicators

Network anomaly — new DTLS peers on UDP/12346:

```

// Assumes firewall/NSG flow logs ingested into CommonSecurityLog
CommonSecurityLog
| where TimeGenerated > ago(7d)
| where DestinationPort == 12346 and Protocol == 'UDP'
| summarize ConnectionCount=count(), FirstSeen=min(TimeGenerated),
              LastSeen=max(TimeGenerated) by SourceIP, DestinationIP
| where ConnectionCount > 1
| order by ConnectionCount desc

```

SSH authorized_keys modification on SD-WAN hosts:

```

// Linux Syslog / CEF events from SD-WAN Controller
Syslog
| where TimeGenerated > ago(7d)
| where SyslogMessage has 'authorized_keys'
| where SyslogMessage has_any ('MODIFY', 'CREATE', 'WRITE', 'chmod', 'chown')
| project TimeGenerated, HostName, SyslogMessage
| order by TimeGenerated desc

```

6. Threat Hunting

6.1 Hunt: SD-WAN Controller SSH Key Enumeration

Deploy the following to enumerate SSH authorized_keys on all SD-WAN Controllers. Any keys not matching your approved device management public keys should be treated as an indicator of compromise.

```
#!/bin/bash
# Run on each SD-WAN Controller via SSH
echo '=== Checking authorized_keys for unexpected entries ==='
for keyfile in /root/.ssh/authorized_keys /home/admin/.ssh/authorized_keys; do
  if [ -f "$keyfile" ]; then
    echo "--- $keyfile ---"
    cat "$keyfile"
    stat "$keyfile"
  fi
done
grep PermitRootLogin /etc/ssh/sshd_config
last -F | head -50 # Recent login history (check for gaps if wiped)
```

6.2 Hunt: SD-WAN OMP Routing Anomalies

Hunt for unexpected TLOC entries or route advertisements in the SD-WAN OMP routing table. An attacker with administrative access to the Controller may inject rogue TLOCs to redirect traffic or establish persistence at the routing layer.

```
# On Cisco SD-WAN Controller – vManage CLI
show omp tlocs | include 'TLOC\|system-ip\|color\|encap'
show omp routes | include 'PREFIX\|via\|color'
# Compare output against your baseline TLOC inventory
# Flag any system-ip or public-key values not matching enrolled devices
```

6.3 Hunt: FMC Audit Log Review

Review FMC audit logs for signs of exploitation or post-compromise activity. Audit logs in FMC are accessible via System > Monitoring > Audit Log. Key patterns to hunt for:

- Any access events from IP addresses not belonging to your management network
- Policy changes (access control rules, NAT rules, intrusion policies) not correlated to a change ticket
- New or modified user accounts — particularly admin-level accounts created outside of provisioning windows
- Bulk API requests — a high volume of API calls in a short window from a single source
- Login failures followed immediately by successful authentication (credential stuffing or bypass exploitation)

6.4 Hunt: SD-WAN Software Version Integrity

UAT-8616 has been documented downgrading SD-WAN software versions to re-expose older CVEs. Verify that all controllers and edge devices are running the expected software version and that no unauthorised version changes have occurred in the past 90 days.

```
// Sentinel KQL – SD-WAN device version change detection
// Assumes SD-WAN telemetry forwarded to Log Analytics
Syslog
| where TimeGenerated > ago(90d)
| where SyslogMessage has_any ('software downgrade','version change',
                                'install completed','upgrade failed')
| project TimeGenerated, HostName, SyslogMessage
| order by TimeGenerated asc
```

7. MITRE ATT&CK Mapping

Tactic	ID	Technique	Application
Initial Access	T1190	Exploit Public-Facing Application	CVE-2026-20182 / 20127: Auth bypass on SD-WAN Controller (UDP/12346). CVE-2026-20079/20131: Auth bypass + RCE on FMC web interface.
Execution	T1059.004	Command and Scripting Interpreter: Unix Shell	Post-exploitation: Attacker executes shell commands on SD-WAN Controller and FMC via root access.
Persistence	T1098.004	Account Manipulation: SSH Authorized Keys	UAT-8616: Injects SSH public keys into authorized_keys on compromised controllers to maintain persistent access.
Persistence	T1543.002	Create or Modify System Process: Systemd Service	Post-exploitation: Threat actors may install systemd services or modify boot-time processes for persistence.
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools	UAT-8616: Clears syslog, wtmp, lastlog, bash_history, and cli-history to remove forensic evidence.
Defense Evasion	T1195.001	Supply Chain Compromise: Compromise Software Supply Chain	UAT-8616: Downgrades SD-WAN software versions via legitimate management APIs to re-expose patched CVEs.
Discovery	T1016	System Network Configuration Discovery	Post-exploitation on FMC: Attacker extracts full network topology, firewall policy, and ACL configuration.
Lateral Movement	T1021.004	Remote Services: SSH	UAT-8616: Uses injected SSH keys and enabled root login to move laterally across SD-WAN infrastructure.
Collection	T1005	Data from Local System	CVE-2026-20133: API information disclosure allows reading of sensitive OS files and configuration secrets.

Impact	T1565.002	Data Manipulation: Transmitted Data Manipulation	FMC compromise: Attacker can silently modify firewall policy on all managed devices, manipulating network security posture.
--------	-----------	--	---

8. Recommended Actions Summary

Actions are prioritised by urgency. CISA Emergency Directive 26-03 mandates federal agency remediation by 17 May 2026. All organisations should treat this timeline as a critical deadline.

Action	Owner	Deadline
Inventory all Cisco Catalyst SD-WAN Controllers, Managers, and FMC instances	IT / Network Ops	Immediate
Block external access to SD-WAN vdaemon (UDP/12346) and FMC web interface (TCP/443) via ACLs	Network / Firewall	Immediate (< 4 hrs)
Apply Cisco patches for all affected SD-WAN releases (see Section 4.1)	Patch Management	17 May 2026 (CISA ED 26-03)
Apply Cisco patches for all affected FMC versions (see Section 4.2)	Patch Management	17 May 2026 (CISA ED 26-03)
Audit SSH authorized_keys and sshd_config on all SD-WAN Controllers and Managers	IR / Network Ops	24 hours
Review FMC audit logs for unauthorised access, policy changes, or new accounts	SOC / IR Team	24 hours
Verify SD-WAN software versions on all devices — check for unauthorised downgrades	Network Ops	24-48 hours
Deploy Sigma/KQL detection rules for SD-WAN and FMC anomalies to SIEM	SOC / Detection Eng.	24-48 hours
Rotate all credentials and API tokens stored in or accessible via SD-WAN Manager / FMC	IAM / Network Ops	48 hours
Engage IR team if any IOCs (Section 5) are identified — treat as active breach	CISO / IR	On detection
Report SD-WAN inventory and remediation status to CISA (federal agencies only)	CISO / Compliance	17 May 2026

9. References

Cisco Security Advisory — CVE-2026-20182 (cisco-sa-sdwan-rpa2-v69WY2SW): <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-sdwan-rpa2-v69WY2SW>

Cisco Security Advisory — CVE-2026-20079 & CVE-2026-20131 (FMC RCE): <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-fmc-rce-NKhnULJh>

Cisco Talos Intelligence — 'Ongoing exploitation of Cisco Catalyst SD-WAN vulnerabilities': <https://blog.talosintelligence.com/sd-wan-ongoing-exploitation/>

Cisco Talos Intelligence — 'Active exploitation of Cisco Catalyst SD-WAN by UAT-8616': <https://blog.talosintelligence.com/uat-8616-sd-wan/>

CISA Emergency Directive 26-03 — Mitigate Vulnerabilities in Cisco SD-WAN Systems: <https://www.cisa.gov/news-events/directives/ed-26-03-mitigate-vulnerabilities-cisco-sd-wan-systems>

CISA KEV Catalog — CVE-2026-20182 Entry (added 14 May 2026): <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

Rapid7 Analysis — CVE-2026-20182 Technical Breakdown: <https://www.rapid7.com/blog/post/ve-cve-2026-20182-critical-authentication-bypass-cisco-catalyst-sd-wan-controller-fixed/>

Tenable FAQ — Cisco SD-WAN Exploitation Campaign: <https://www.tenable.com/blog/faq-about-the-continued-exploitation-of-cisco-catalyst-sd-wan-vulnerabilities-uat-8616>

The Hacker News — Cisco Catalyst SD-WAN Controller Auth Bypass Actively Exploited: <https://thehackernews.com/2026/05/cisco-catalyst-sd-wan-controller-auth.html>

Arctic Wolf — CVE-2026-20079 & CVE-2026-20131 Analysis: <https://arcticwolf.com/resources/blog/cve-2026-20079-cve-2026-20131/>

Security Affairs — CISA adds CVE-2026-20182 to KEV: <https://securityaffairs.com/192157/hacking/u-s-cisa-adds-a-flaw-in-cisco-catalyst-sd-wan-to-its-known-exploited-vulnerabilities-catalog.html>

Help Net Security — Cisco SD-WAN Manager exploitation, 48 firewall vulnerabilities: <https://www.helpnetsecurity.com/2026/03/05/cisco-cve-2026-20128-cve-2026-20122-exploited/>

NVD — CVE-2026-20133 Detail: <https://nvd.nist.gov/vuln/detail/CVE-2026-20133>

This report was compiled from publicly available threat intelligence as of 15 May 2026. Cisco patches are available for all five CVEs — apply immediately. CISA ED 26-03 deadline: 17 May 2026. All detection content requires environment-specific validation before deployment.